



File No.: EXP202302933

RESOLUTION OF FILE OF ACTIONS

From the actions carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: On January 20, 2023, a complaint was filed with the Spanish Agency for Data Protection against DIGI SPAIN TELECOM, S.L., with NIF B84919760 (hereinafter, the complained party).

The reasons for the complaint are as follows:

The complainant states that their phone number ***PHONE.1, of which they are the owner, was cloned by the company DIGI SPAIN TELECOM, S.L.U. ("DIGI"), since on September 4, 2021, without any security measures aimed at reliably identifying the person who requested it, a third party, impersonating the identity of the complainant, requested the cloning of the phone, with the aim of making calls to the banking entity BANCO PICHINCHA ESPAÑA, S.A., and thus carrying out certain operations that resulted in a total of 50,000 euros transferred from their bank account to other accounts.

A police report is provided (the case was provisionally dismissed on November 24, 2022, for lack of sufficient justification for the commission of the crime) and claims made.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to the complained party/ALIAS, so that they could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on March 13, 2023, as stated in the certificate in the file.

On April 13, 2023, a response was received by this Agency indicating the following:

"The complainant themselves refers in their writing to the provisional dismissal of the criminal case by Order of the ***COURT.1 for lack of proper evidence of the commission of the crime. An Order that, contrary to what is indicated in the writing received by DIGI, is not included among the documentation provided, which is why it could not be studied by this party. Therefore, from the available information, the provisional dismissal occurs under Article 461.1 of the LEC and not by the second point of the same article.

Consequently, it is not that the author or accomplices of a hypothetical crime could not be identified (the complaint mentions a certain A.A.A. and a certain B.B.B. and we presume that it could have been investigated, even the IBAN codes of the recipient accounts and the names of their actual holders if they were not those), but rather that the mere existence of such a crime could not be verified.

Therefore, since the commission of a crime is not properly justified, deducing the actions of DIGI in accordance with due diligence is not possible because:

1º) It has not been confirmed that the principle of integrity and confidentiality was breached by the actions of DIGI.

2º) The insufficiency of security measures has not been confirmed. This party cannot accept that it is sufficient for the complainant to indicate in their writing that the Police may have pointed this out in a report, not only because the report was not provided but also because such an opinion may be exempt from criticism and counter-argumentation, especially since no material arguments are provided to support it.

3º) The security breach that could give rise to a notification obligation under data protection regulations has not been confirmed.

Notwithstanding the above, as soon as the complainant informed of such facts, DIGI proceeded to adopt the following measures aimed at resolving the situation and minimizing any possible risk that could arise:

a) Rectification of the element causing the incident: suspending the SIM activated in a presumably

irregular manner. It should be noted for these purposes that the mobile line was activated on the presumably fraudulent SIM from the night of 04-09-21 until the afternoon of 07-09-21, when the supposedly irregular SIM was deactivated and a new SIM duplicate was provided to the complainant to regain control of their line. It is worth mentioning that for the generation of this duplicate, the double identification procedure of the complainant was also followed, first by phone in DIGI's customer service and then in person at a DIGI dealer, where the complainant had to show their identity document.

b) In relation to the above, DIGI internally investigated the events that occurred to detect the origin of the incident. Since this company is unaware of a possible loss by the complainant of their identification document, and/or other data that could have been used to obtain the duplicate of the SIM card, measures were imposed regarding the involved Distributor for a possible contractual breach by them of the policies established by this company for customer identification. For this reason, as has been stated, DIGI contacted the Distributor to clarify the events that occurred, as well as to remind and reiterate the importance of complying with the established procedures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/8

c) Additionally, DIGI has assessed the facts claimed by the claimant, providing the requested information in exercising the right of access.

Regarding the scope of the Company's actions, the incident reported by the claimant would arise from a supposed case of a SIM duplicate not requested by the claimant.

Specifically, a call was received at 20:43 on 04-09-21 from a person who, having passed the identification test (name-surname, phone number, identity document, and last four digits of the account number) and thus identifying themselves as the claimant, requested a duplicate of the SIM card associated with that number. After passing the test, the duplicate was granted, and the necessary code was provided to be presented in person at a Dealer along with their Identity Document to collect the SIM and complete the duplication process. The claimant contacted indicating that they had no network on 06-09-21, requesting the SIM duplicate once the aforementioned identity test was passed. The duplication process was completed on 07-09-21.

Although DIGI has verified that this is an isolated incident, in order to ensure and reinforce the security in the processing of personal data of its customers, this Company has modified the existing procedures for issuing SIM card duplicates as of the date when the analyzed events occurred, as will be explained later.

Furthermore, this company wishes to highlight that the damages claimed by the claimant that have occurred in this case specifically stem from the customer identification processes established by the banking entities themselves. In this regard, as the claimant states in their complaint, the alleged impersonator managed to bypass the remote identification security protocols of the banking entity and thus cause the consequent harm. It should be emphasized that among the security elements of the banking entity would be the balance, payroll amount, income, last transfer, co-holder data, which the alleged impersonator would not have satisfactorily answered according to what is stated in the claimant's writing. Yet, the banking entity allowed this alleged impersonator to access the claimant's banking data. In this sense, among the security elements of the banking entity, the account number would not be included— which was indeed subject to one of the security mechanisms for the authentication of DIGI, indicating the existence of a security incident prior to any action by DIGI and unrelated to this Company, since the alleged impersonator could have accessed the claimant's account number either through their banking entity or through the claimant themselves. Given these collateral damages that may arise for the customers of this Company due to the acquisition of a SIM card duplicate, and in light of the identified risks, DIGI has focused its main efforts and objectives on improving these processes.

As has been previously reported by this company, the acquisition of SIM card duplicates through identity theft of customers is

C/ Jorge Juan, 6

a current issue in which not only the clients themselves are being directly affected, but also the telecommunications operators, who bear the obligations imposed by the sectoral telecommunications regulation regarding data retention, as well as the applicable regulations on the protection of personal data, in addition to the collateral consequences that this may generate, such as the potential loss of clients.

Thus, in the past year, DIGI has changed and reinforced its internal processes for issuing duplicate SIM cards on several occasions, addressing their effectiveness and the detected risks, always with the aim of mitigating the existing contingency regarding requests for duplicate SIM cards made under identity theft.

Below, the measures adopted to prevent such identity theft are detailed, as well as a detailed report on the technical and organizational measures implemented by the data controller to verify the identity of the holder of a SIM card at the time of requesting a duplicate, whether through the in-person channel, the telephone channel, or any other established for this purpose (e.g., the web platform).

For the issuance of the duplicate SIM card that allegedly occurred irregularly, the Point of Sale checked the identity document of the requester and proceeded to enter into the system the phone number for which the duplicate is requested, in addition to the identity document number. Since both pieces of information matched the data contained in DIGI's databases, the generation of the duplicate SIM was authorized, for which, in the next step, the system requests the entry of the ICCID of the new SIM card. For these purposes, the verification of the identification document and the match between the provided data is the only way to obtain a duplicate SIM, with the issuance of the duplicate SIM being rejected if the provided data does not match the data registered by DIGI.

This second identification protocol has been confirmed by the Dealer:

Therefore, from the checks that have been carried out by DIGI, it has been determined that the cause that has motivated the present claim is the allegedly irregular issuance of a duplicate SIM card, after the identity of the claimant was allegedly usurped by an individual who may have previously had access to the personal information of the claimant, for reasons unrelated to DIGI, and who, therefore, was already aware of it.

Considering the above, it can be evidenced that DIGI had sufficient technical and organizational measures for verifying the identity of clients when requesting a duplicate SIM, in order to prevent possible incidents such as the one that has led to the present claim, in such a way that they could reasonably be classified as adequate and sufficient, with no significant failure detected in these measures, but rather that the alleged harmful result occurred as a consequence of a loss of confidentiality of the claimant's personal data prior to this and for reasons entirely unrelated to DIGI, in addition to the security protocol implemented by the entities.

banking for the identification of their own clients, in order to avoid incidents like the one we are addressing.

Furthermore, the indications made by the claimant regarding the judicial order that addressed the facts suggest that the mere existence of the crime could not be confirmed.

Additionally, in relation to the case at hand, DIGI has been able to confirm that once it became aware of the issuance of the duplicate SIM card not authorized by the claimant, all necessary actions were initiated to rectify the detected irregularity, as well as to prevent possible unauthorized duplicate SIM card issuances.

THIRD: On April 20, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted was admitted for processing.

FOURTH: On April 24, 2023, this Agency received a new response indicating the following:

At the time of the duplicate request, it was required to authenticate first by phone, providing the full name, phone number, identity document number, and the last four digits of the bank account number of the line holder. Document 1 includes a copy of the call recording.

As can be heard in the recording, the requesting person passes the security filter without any problem, being identified as the line holder, and this is reflected in their customer history.

Regarding the presentation of the ID when collecting the physical card at the involved distributor, as explained to the Agency, the procedure established by DIGI required that the line holder (after prior telephone identification) visit a DIGI distributor, identify themselves by physically presenting their original identity document, and finally, the number of that identity document had to be entered into the system enabled by DIGI for that purpose. A screenshot of the mentioned system is attached below, where it can be verified that the procedure is described, and the entry of the phone number for which the duplicate is being requested, along with the identity document number of the holder, is required. Thus, the system does not allow the generation of a SIM duplicate if (1) the customer has requested the duplicate by phone and has been correctly identified by phone; (2) the customer has identified themselves (for the second time) in person at a DIGI distributor using their original identity document; (3) all data has been correctly entered into the system to enable the generation of the duplicate. This is the procedure that was defined and had to be followed to obtain the duplicate SIM card of the claimant, and there is no argument (unless a crime had been committed) to assert that the procedure was not followed as implemented by DIGI.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/8

First of all, it is important to mention the prior steps taken for the proper adaptation of the measures to be taken for the specific case:

1st) Preliminary review of their history regarding similar incidents. This party understands it is relevant to point out that neither before nor after the incident subject to this file has the distributor been involved in any other analogous situation, having executed their contract in accordance with the rules and protocols under analysis, and it is a distributor that continues to collaborate with DIGI as they fulfill their obligations.

2nd) Preliminary review of the history and actions of the distributor.

3rd) Interview with the distributor to discuss the situation and, specifically, their actions regarding it.

There being no element that would cast doubt on the correct actions of all employees and collaborators of DIGI, including the distributor, the following measures were imposed purely in accordance with the principle of precaution:

- Reminder to the distributor of the importance of correct authentication due to the potential damages it can cause both to the customer and to DIGI, and of course, to the distributor themselves.
- Reminder to the distributor of the verification processes against usurpations.

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f) and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative proceedings.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Security of processing

Article 32 of the GDPR stipulates the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/8

"1. Taking into account the state of the art, the costs of application, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

III

Principles relating to processing

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

IV

Conclusion

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/8

The complaint specifies that the claimant's phone card was cloned by the company DIGI SPAIN TELECOM, S.L.U. ("DIGI"), since on September 4, 2021, without any security measures aimed at reliably identifying the person who requested it, a third party impersonated their identity.

The entity being complained against has provided the security measures it has implemented to prevent impersonation or fraud in requests for duplicate SIM cards, which were followed in the case subject to the complaint: the requester was fully identified by phone and provided their ID at the physical store.

On the other hand, the claimant also filed a complaint regarding these events, which was dismissed for lack of sufficient justification for the commission of the crime.

Therefore, based on the information provided in the previous paragraphs, no evidence has been found that substantiates the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

In accordance with the above, the Director of the Spanish Agency for Data Protection, IT IS AGREED: FIRST: TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to DIGI SPAIN TELECOM, S.L. and to the claimant.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-020323

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es